Unique QR Safety-Tag Engine

QR Code Generation for Pet Safety Tags — companion_pet module

PawGuard Platform | pawguard-backend (FastAPI + PostgreSQL + Redis + ARQ) | Prepared for Team Review

1. Purpose

Every registered pet can be issued one active QR “safety tag.” Anyone who finds a lost pet can scan the tag with a phone camera and instantly see the pet's emergency-safe details — without an app, a login, or seeing the owner's private contact information.

2. How the Token Is Generated

The backend never stores a scannable QR image itself — it generates a cryptographically random secret token and only the frontend renders that token as a QR image. This keeps the raw secret out of the database entirely:

1. Owner calls POST /companion-pets/{pet_id}/safety-tag (permission: safety_tag:manage).
2. Backend generates raw_token = secrets.token_urlsafe(32) — a 256-bit, URL-safe random string.
3. Backend computes token_hash = SHA-256(raw_token) and stores only the hash, plus a token_prefix (first 8 characters, for display/support use).
4. The raw_token is returned in the API response exactly once and is never persisted or logged.
5. The client encodes raw_token into a public scan URL (e.g. https://pawguard.app/tags/scan?t=RAW_TOKEN) and renders it as a QR image for printing on a collar tag.

3. Why Hash-Only Storage

- If the database were ever compromised, an attacker recovers only SHA-256 hashes — not usable tokens.
- Re-provisioning a tag (lost/damaged tag) simply generates a new token and invalidates the old one; only one active tag per pet is allowed (unique partial index on pet_id where is_active = true).
- The prefix lets support staff identify a tag from a photo without ever exposing the full secret.

4. Data Model — pet_safety_tags

Column	Type	Notes
id	UUID (PK)	Tag identifier
pet_id	UUID (FK → companion_pets)	One active tag per pet (partial unique index)
token_hash	VARCHAR(64), unique, indexed	SHA-256 hex digest of the raw token
token_prefix	VARCHAR(12)	First 8 chars of raw token, for support lookup
is_active	BOOLEAN	False once rotated/revoked
scan_count	INTEGER	Incremented on every successful public scan
last_scanned_at	TIMESTAMPTZ	Updated on every successful scan

5. Public Scan Flow & Abuse Protection

→ → →

- Endpoint is public (no login) but rate-limited via Redis: 20 requests / 60 seconds per IP, to block brute-force token guessing.
- Response includes pet name, species, breed, photo, and an owner-provided emergency note — never owner name, phone, or address (PII is deliberately excluded from this response model).
- scan_count and last_scanned_at are updated so the owner can see tag activity from their app.

Source: companion_pet/service.py (provision_safety_tag, scan_safety_tag), companion_pet/models.py (SafetyTag). Generated from the pawguard-backend codebase.